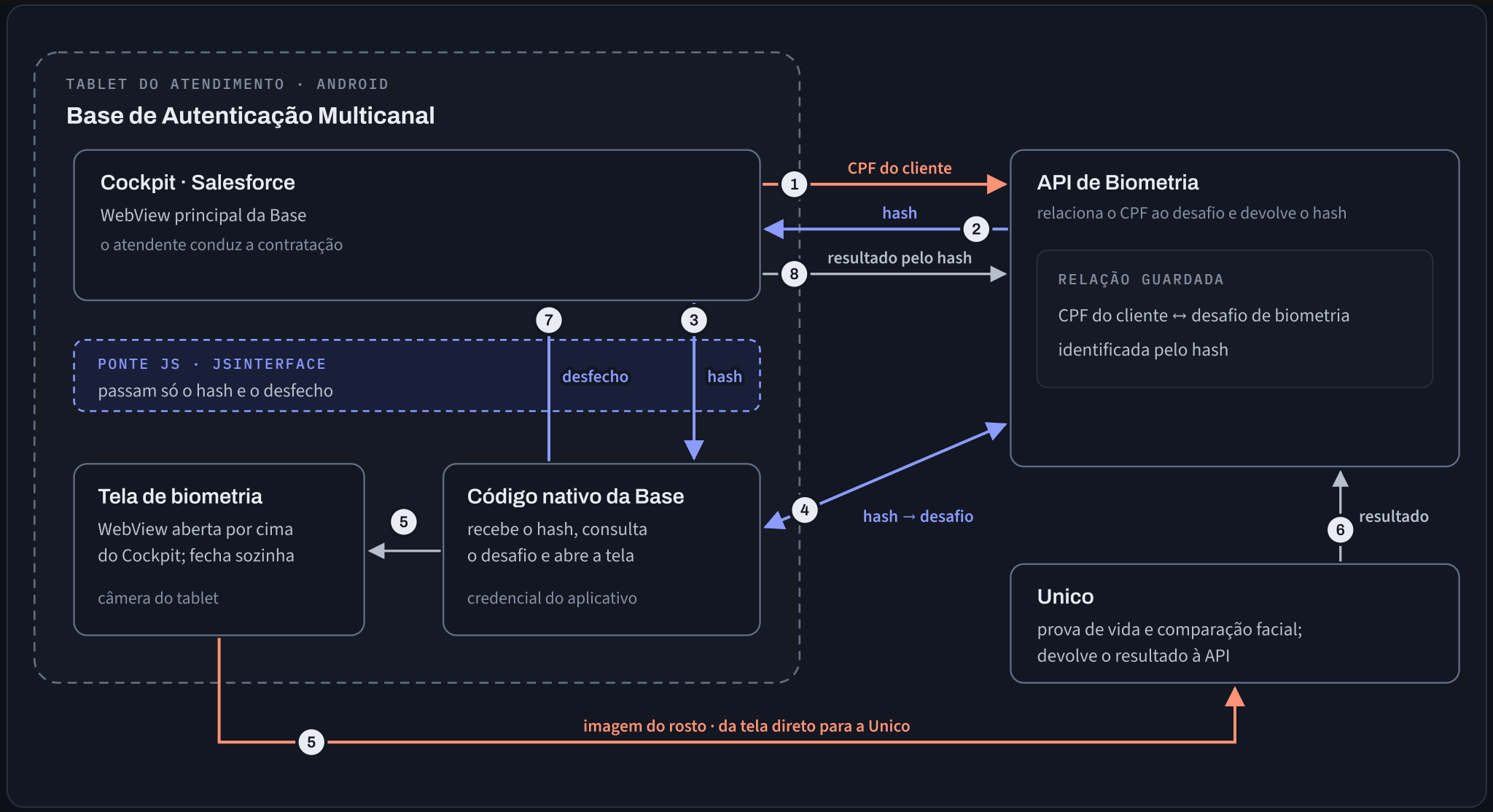
DESENHO ARQUITETURAL · BASE DE AUTENTICAÇÃO MULTICANAL

Biometria por hash: só um identificador atravessa a ponte JS

O Cockpit pede o desafio à API de Biometria informando o CPF e recebe de volta um **hash**. Só esse hash passa pela ponte JS até a Base de Autenticação Multicanal. Com ele, a Base consulta a API, descobre qual é o desafio e abre a biometria. **Nenhum dado pessoal passa pela ponte**: o CPF fica entre o Cockpit e a API, e a imagem do rosto vai da tela de biometria direto ao parceiro.

VISÃO DE COMPONENTES

Quem fala com quem



só o hash ou o desfecho — dado pessoal (CPF, rosto): nunca pela ponte — resultado e controle

1. O Cockpit chama a API de Biometria com o **CPF do cliente**. A API relaciona o CPF ao desafio e gera um hash.
2. A API responde ao Cockpit **só com o hash**.
3. O Cockpit entrega o hash à Base **pela ponte JS**.

4 A Base consulta a API com o hash e recebe o desafio: **biometria**.

5 A Base abre a **tela de biometria** por cima do Cockpit; o rosto do cliente vai direto para a Unico.

6 A Unico devolve o **resultado à API**, que o grava no desafio daquele hash.

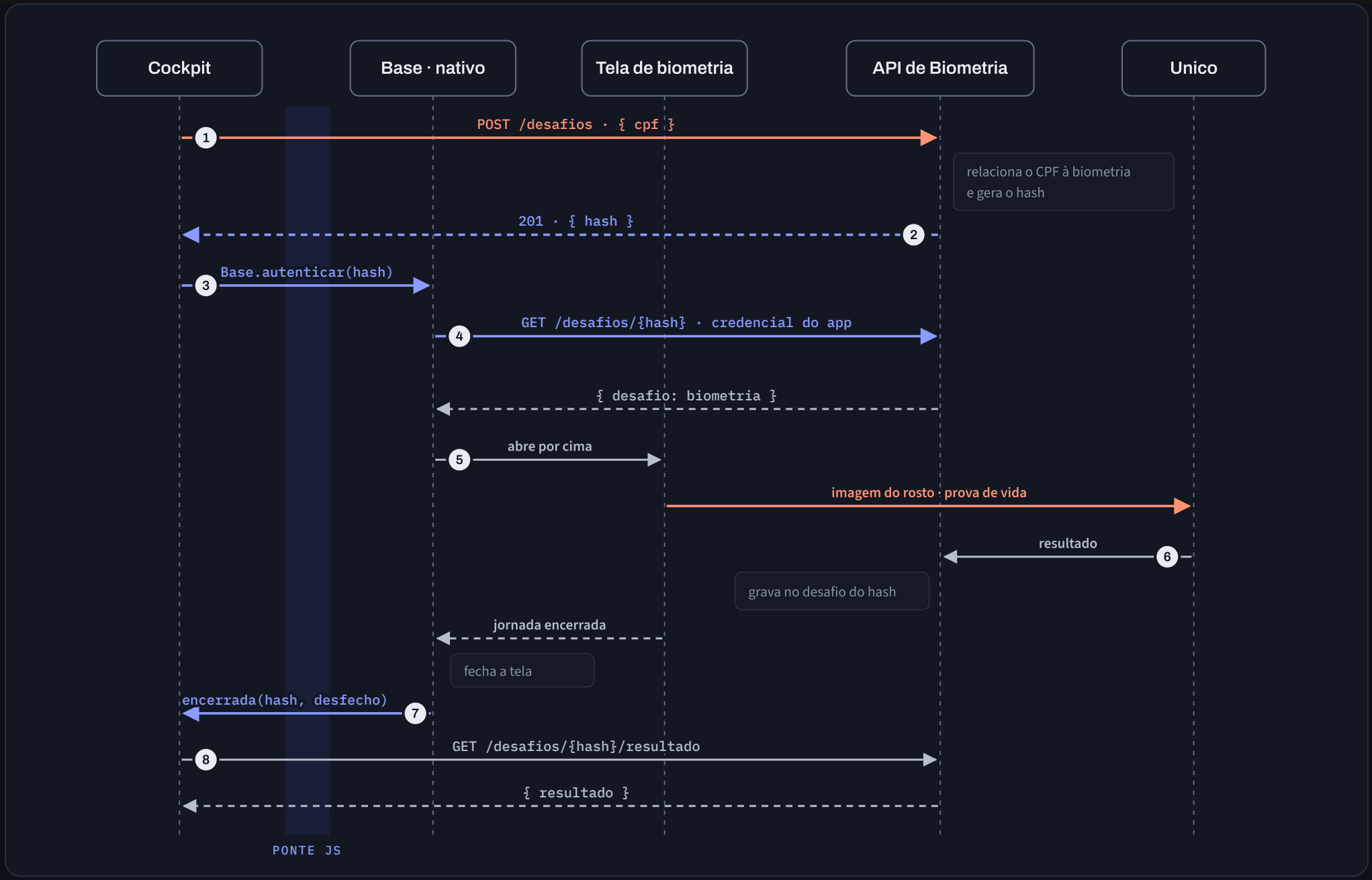
7 A tela se fecha e a Base avisa o Cockpit pela ponte: **hash + desfecho**.

8 O Cockpit **confirma o resultado na API** pelo hash, e a contratação segue.

SEQUÊNCIA

As chamadas, na ordem

A faixa azul marca a ponte JS. Tudo o que cruza a faixa é o hash ou o desfecho.



Rotas, métodos e campos são ilustrativos. Setas tracejadas são respostas.

A PONTE JS

O que atravessa e o que fica de fora

Passa pela ponte

- o hash do desafio, do Cockpit para a Base
- o desfecho (concluída, cancelada ou erro) com o mesmo hash, da Base para o Cockpit

Nunca passa pela ponte

- CPF, nome ou qualquer dado do cliente
- imagem do rosto e resultado detalhado da biometria
- URL da biometria, credenciais e tokens

> Mudança em relação ao desenho anterior da ponte: a URL da biometria deixa de passar por ela. A Base busca o desafio na API com o hash, e a ponte fica restrita a um identificador sem significado fora da API.

REQUISITOS DO HASH

Para o hash não virar o dado sensível

Aleatório, nunca calculado do CPF

O nome é "hash", mas o valor precisa ser gerado ao acaso (128 bits ou mais). Um hash do CPF se reverte por tentativa: o CPF tem poucas combinações possíveis.

Validade curta

O desafio expira em minutos. Hash vencido é recusado pela API, e o Cockpit pede um novo.

Uso único

A primeira consulta da Base marca o hash como "em uso". Uma segunda consulta com o mesmo hash é recusada.

Só a Base consulta o desafio

A consulta do passo 4 exige a credencial do aplicativo. Um hash vazado não abre a biometria fora de um tablet do banco.

A consulta não devolve o CPF

A Base recebe só o tipo de desafio e o necessário para abrir a tela. O vínculo com o CPF fica dentro da API.

Quem vale é a API, não a ponte

O desfecho que chega pela ponte é um aviso. Qualquer script na página poderia imitá-lo. Antes de seguir com a contratação, o Cockpit confirma o resultado na API (passo 8).

EM ABERTO

O que precisa ser definido

1. **Quem é a API de Biometria neste desenho.** No desenho atual, a API de Biometria é do parceiro Unico. Este fluxo exige uma API do banco que guarde a relação hash → CPF e o estado do desafio. Definir se é uma API nova do time de desenvolvimento ou a evolução de uma existente.
2. **De onde o Cockpit chama a API (passos 1 e 8).** Pelo servidor do Salesforce, o CPF não passa pelo tablet; pelo navegador do Cockpit, passa pela WebView, ainda que fora da ponte.
3. **Como a Base se identifica na API (passo 4).** Credencial do aplicativo, certificado do aparelho ou login do atendente.
4. **Como o resultado chega da Unico à API (passo 6).** Aviso da Unico ou consulta da API, e o que acontece se o resultado atrasar.
5. **Prazo de validade do hash** e o que o atendente vê quando ele expira no meio do atendimento.

> Este desenho antecipa o padrão do Autenticador Demais Canais: o hash cumpre o papel do id de solicitação, e a Base já passa a abrir o que a API indicar. Quando o Autenticador existir, a troca acontece do lado da API, sem mudar a ponte.